

Facilitator talking points — Governance and Access Control

Participant guide: `05-participant-guide.md` **Facilitator demo:** `facilitator-demo.py` **Scheduled:** 3:20 PM–3:50 PM · 30 minutes

Delivery map

Time	Minutes	Mode	Surface and focus
0:00–0:03	3	Slides	Access incident, assignment, and smoke-test boundary
0:03–0:07	4	Slides	Authorization chain and evidence to collect
0:07–0:16	9	Facilitator demo	Restricted-user failure, administrator repair, and unchanged rerun
0:16–0:20	4	Slides and discussion	What the successful repair proves and does not prove
0:20–0:24	4	Facilitator demo	Table and column lineage in Catalog Explorer
0:24–0:27	3	Facilitator demo	Consumer Lending Domain in Discover
0:27–0:30	3	Participant guide and discussion	Complete the incident handover

1. Access is a chain of independent gates

Use the incident:

A risk analyst can discover `hc_workshop.workshop_shared.fpd_analysis`, but cannot query it.

The request must pass:

```
Open notebook → use SQL warehouse → identify runtime identity  
→ USE CATALOG → USE SCHEMA → SELECT → return authorized result
```

Passing one gate does not prove the next gate will pass.

2. Identify the executing identity

- A user, service principal, or group can hold permissions.
- The runtime identity is the user or service principal executing the request.
- Groups contribute effective access through membership; the group is not the interactive user returned by `current_user()`.
- A scheduled Job may use a different **Run as** identity from the person who configured it.
- Confirm the runtime identity before changing grants.

3. Separate workspace access from data access

- Notebook **CAN RUN** controls whether the identity can execute the workspace asset.
- SQL warehouse **CAN USE** controls whether it can submit work to that warehouse.
- Unity Catalog privileges control access to the governed data object.
- Opening the notebook and using its warehouse do not prove the view can be queried.

4. Explain the Unity Catalog read path

- **USE CATALOG** allows traversal into `hc_workshop`.
- **USE SCHEMA** allows traversal into `workshop_shared`.
- **SELECT** allows rows to be read from `fpd_analysis`.
- **BROWSE** supports discovery and metadata visibility; it does not grant row access.
- Privileges may be direct, inherited from a parent securable, or received through group membership.

5. Diagnose and repair the incident

- The restricted user can run the notebook, use the warehouse, discover the asset, pass `USE CATALOG` , and has `SELECT` .
- The unchanged query fails because `USE SCHEMA` is missing.
- Record the exact error, request ID, runtime identity, object, action, compute, and permission evidence.
- Grant only `USE SCHEMA` to the dedicated restricted group.
- Rerun the same SQL with the same user, warehouse, and object.
- Ten returned rows verify this access repair; they do not validate the FPD5 business definition or prove unrestricted row visibility.

6. Apply the narrowest repair

- Preserve the failing request and change one authorization variable at a time.
- Do not use `ALL PRIVILEGES` as a troubleshooting shortcut.
- Do not grant access to the person reporting the error until the executing identity is known.
- A successful unchanged rerun provides stronger diagnostic evidence than changing the query and the permission together.

7. Use lineage for impact analysis

- Lineage shows upstream sources and downstream dependencies.
- Follow `fpd_analysis` → `fpd_metrics` → `verified dashboard or analysis` .
- Use it to decide which assets require retesting after a definition, schema, access, or availability change.
- Lineage does not grant access, prove correctness, or replace audit evidence.

8. Separate discovery from authorization

- **Discover Domains** organize trusted assets by business purpose.
- **Consumer Lending > Origination Risk** helps consumers find `fpd_analysis` .
- Domain placement proves curation for discovery; it does not grant `USE CATALOG` , `USE SCHEMA` , or `SELECT` .
- Use Discover for business navigation and Catalog Explorer for detailed metadata, permissions, and lineage.

Closing handover

Participants should be able to state the runtime identity, failed gate, evidence, narrow repair, unchanged verification, downstream assets to retest, Domain boundary, owner, risk, and recovery action.